

Basic Concepts of Cybersecurity



Cyber Security Fundamentals

- CIA Triad
- Foundations of Infosec
- Cybersecurity Risk Management
- Motives Behind Attacks
- Need for Security
- What is security posture

Labs

- Students will perform **security posture assessment**
- Students will use **OSINT** to gather information
- Students will use **Google dorks** for performing various operations
- Students will use **shodan.io** for analysis

Foundation of Information Security (InfoSec)

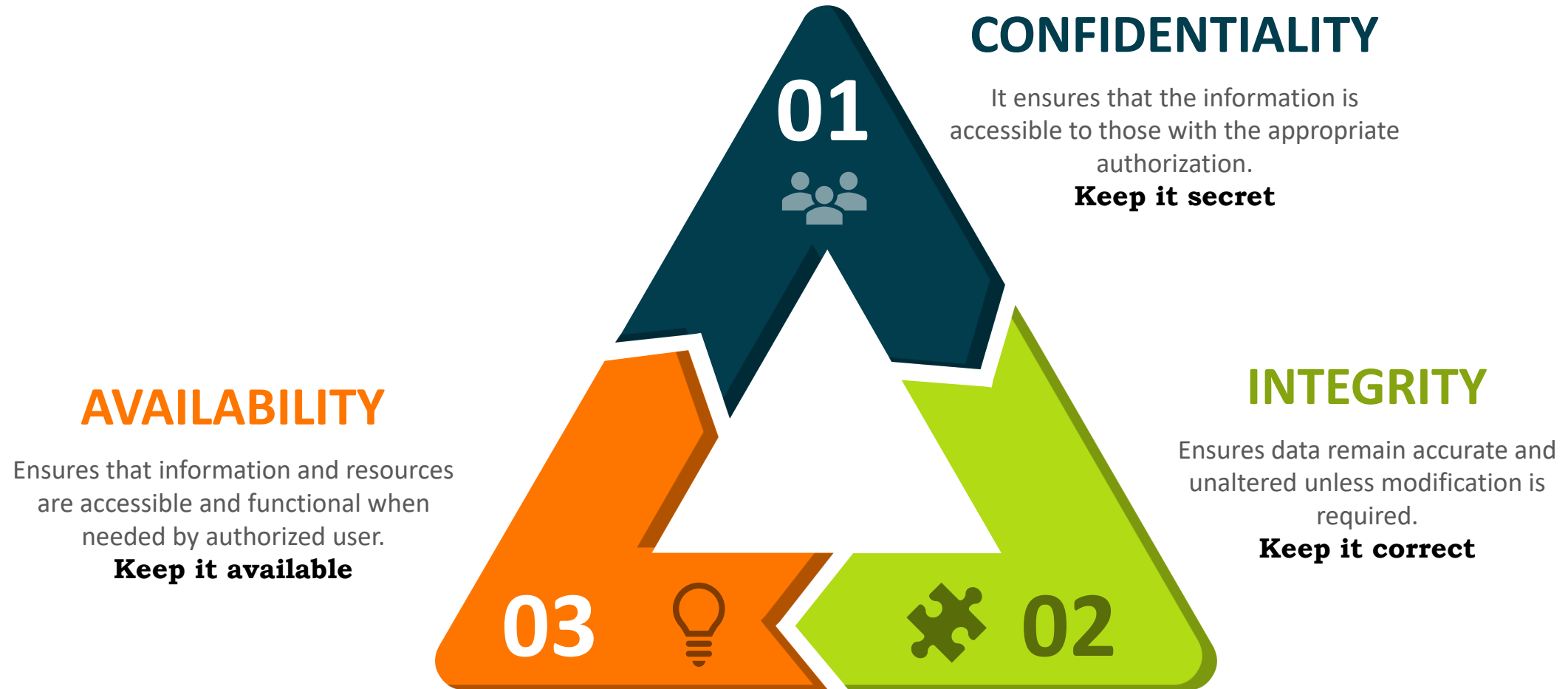
- The foundation of Information Security (InfoSec) is built on a small set of core principles, models, and practices that guide how we protect data, systems, and networks against threats.
- Think of it as the base layer of cyber security – everything else is built on top of these fundamentals, like:
 - firewalls,
 - antivirus,
 - SIEM,
 - Zero Trust,
 - cloud security



Core Foundation

- CIA Triad – Core Foundation
- AAA Model – Access Control Foundation
- Risk Management – Decision Foundation
- Defence in Depth – Protection Layering
- People – Process – Technology (PPT)
- Security Policies & Frameworks
- Security Controls (Three Types)
- Continuous Monitoring & Improvement

CIA Triad (Core Foundation)



Keep it secret, Keep it correct, Keep it available



Confidentiality

- Confidentiality ensures that only authorized users can access information.
- If someone is not authorized, they must NOT be able to see or read the data.
- Confidentiality breaches may occur due to improper data handling or a hacking attempt.
- Confidentiality controls include data classification, data encryption, and proper disposal of equipment (like DVD, USB, Blu-Ray disks etc.)
- Examples
 - ✓ Vault in a bank – only authorized persons can open it.
 - ✓ Only you can read your email inbox



Controls Used for Confidentiality

Method	Explanation
Authentication	Username + Password, Biometrics
Authorization	Role-Based Access Control (RBAC)
Encryption	Data is unreadable without key
MFA (Multi-Factor Authentication)	2 or more login factors
Firewalls	Block unauthorized access
Data Classification	Public / Private / Confidential

Integrity

- Integrity ensures that the data is accurate, complete and has not been modified without authorization.
- Integrity is the trustworthiness of the data or resources in the prevention of improper and unauthorized changes.
- The assurance that information is sufficiently accurate for its purpose.
- It may include “checksum”.
- Examples
 - Sealed exam paper – if seal is broken, integrity is lost.
 - A hacker changes bank balance from ₹10,000 to ₹1,00,000
 - Website content is modified by attackers



Controls Used for Integrity

Method	Explanation
Hashing (SHA, MD5)	Detect data changes
Digital Signatures	Ensure data is genuine
Checksums	Error detection
Access controls	Prevent unauthorized edits
Version control	Track changes



Availability

- Availability ensures that data and systems are accessible when needed by authorized users.
- Availability is the assurance that the systems responsible for delivering, storing and processing information are accessible when required by authorized user.
- Examples
 - Website/server crash
 - DoS/DDoS attacks
 - Power failure
 - Hardware failure
 - Ransomware locks system



Controls Used for Availability

Method	Explanation
Backups	Data recovery
Redundancy	Spare systems
Load balancing	Share traffic
Disaster recovery plan (DRP)	Restore quickly
UPS/Generators	Power backup
Anti-DDoS protection	Prevent attacks

Cybersecurity Risk Management

- Cybersecurity Risk Management is the structured process of *identifying, analyzing, prioritizing, and controlling risks* that threaten an organization's information, systems, and operations.
- It is the process of reducing the chances and impact of cyber attacks.
- Main Objectives
 - Protect sensitive data (PII, financial, IP)
 - Prevent business disruption
 - Reduce financial & reputational loss
 - Meet compliance requirements
 - Support informed security decisions



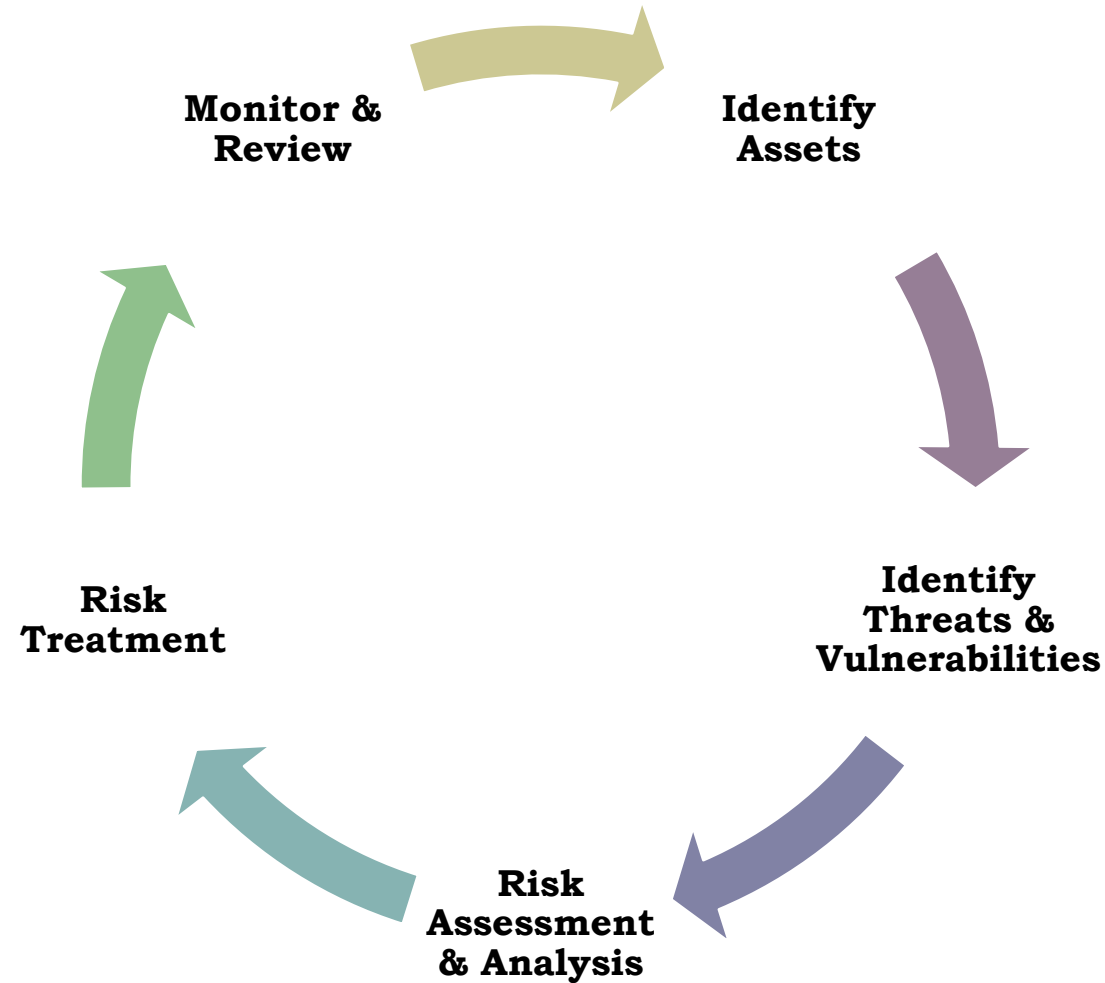
Core formula for Risk calculation

$$\text{Risk} = \text{Threat} \times \text{Vulnerability} \times \text{Impact}$$

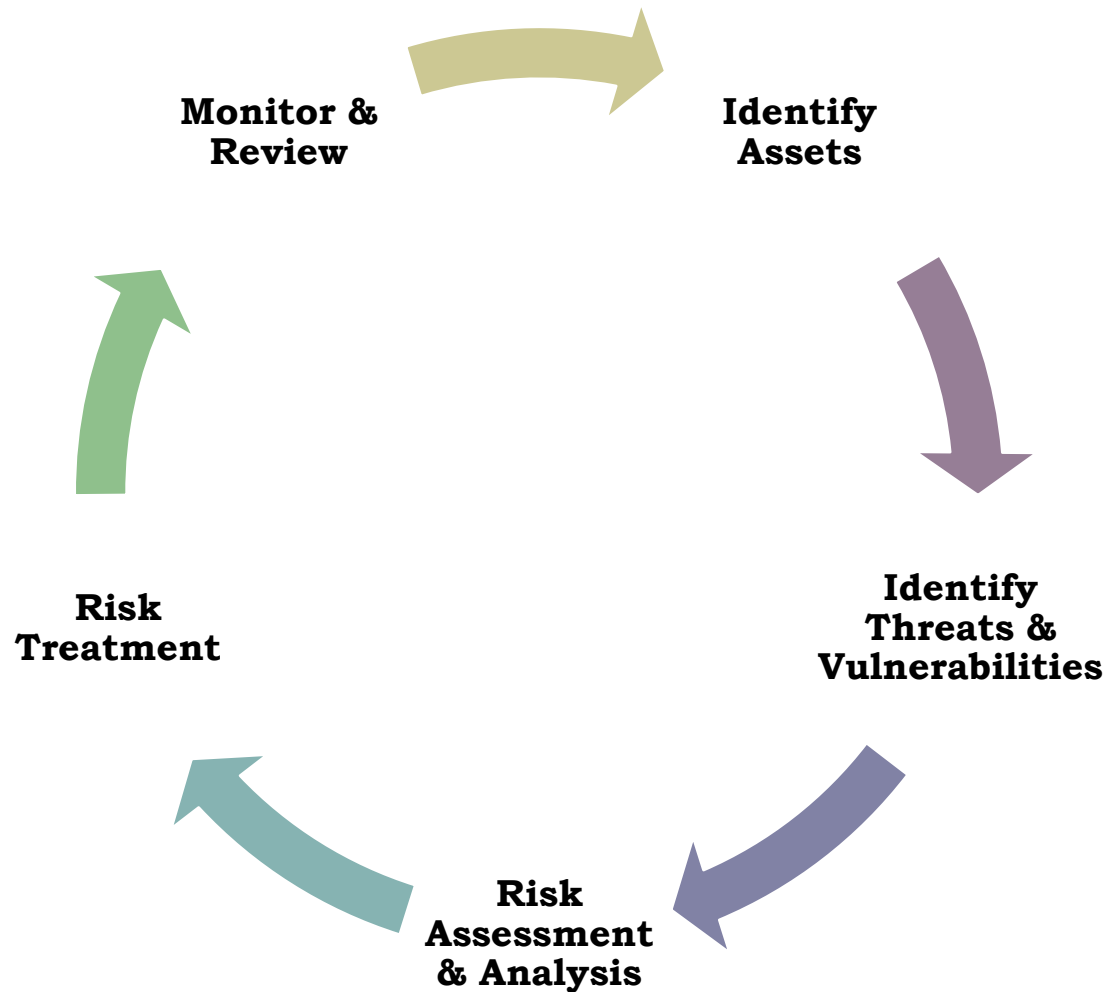
- Example:
 - **Threat:** Ransomware
 - **Vulnerability:** Unpatched system
 - **Impact:** High business downtime
- Result: High Risk



5 Key Phases of Cyber Risk Management



5 Key Phases of Cyber Risk Management



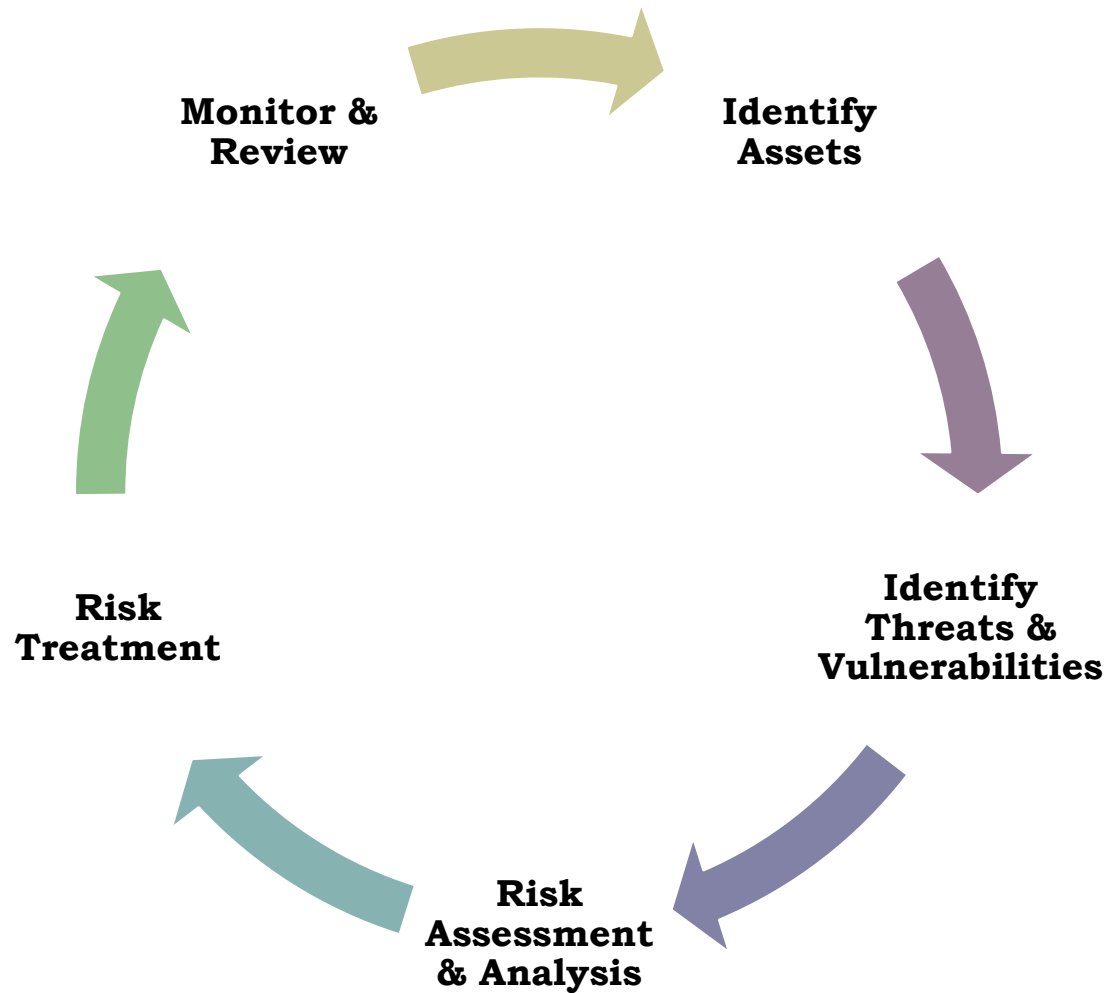
Identify Assets

List what you must protect:

- ✓ Servers
- ✓ Databases
- ✓ Applications
- ✓ Endpoints
- ✓ Cloud resources
- ✓ Sensitive data



5 Key Phases of Cyber Risk Management

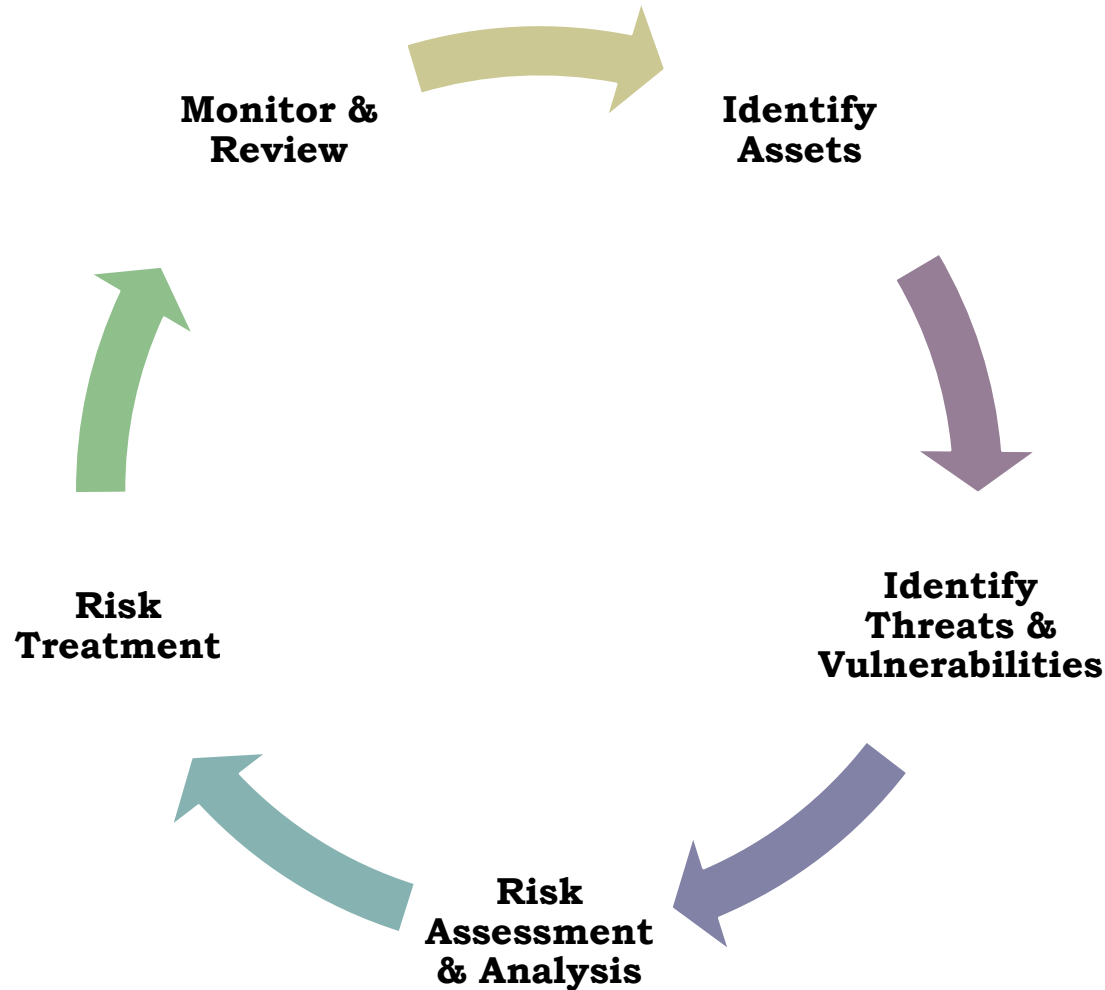


Identify Threats & Vulnerabilities

Threats	Vulnerabilities
Malware	Outdated software
Insider threat	Weak passwords
Phishing	No MFA
DDoS	No rate-limiting



5 Key Phases of Cyber Risk Management



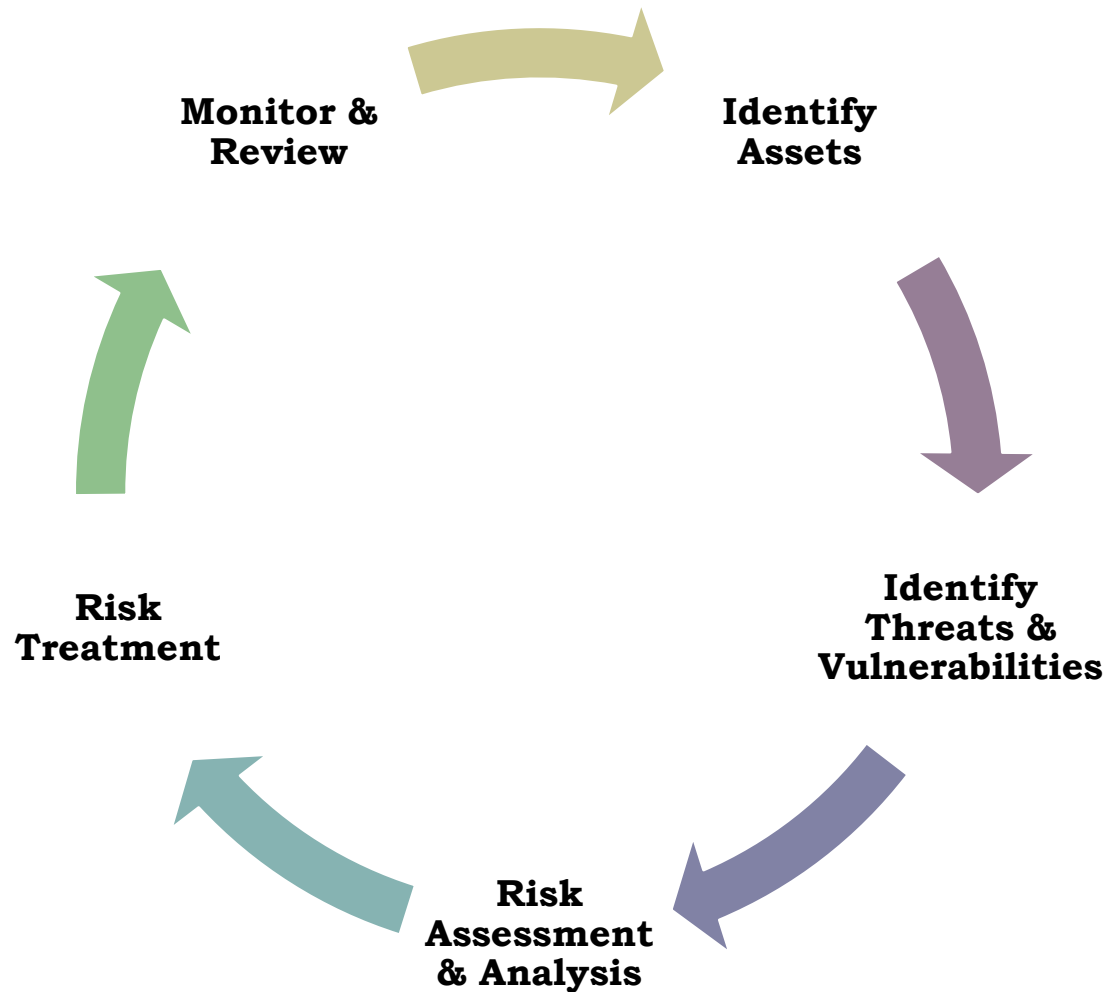
Risk Assessment & Analysis

Each risk is rated by **Impact** & **Likelihood**:

Impact / Likelihood	Low	Medium	High
High Impact	Medium	High	Critical
Low Impact	Low	Medium	High



5 Key Phases of Cyber Risk Management

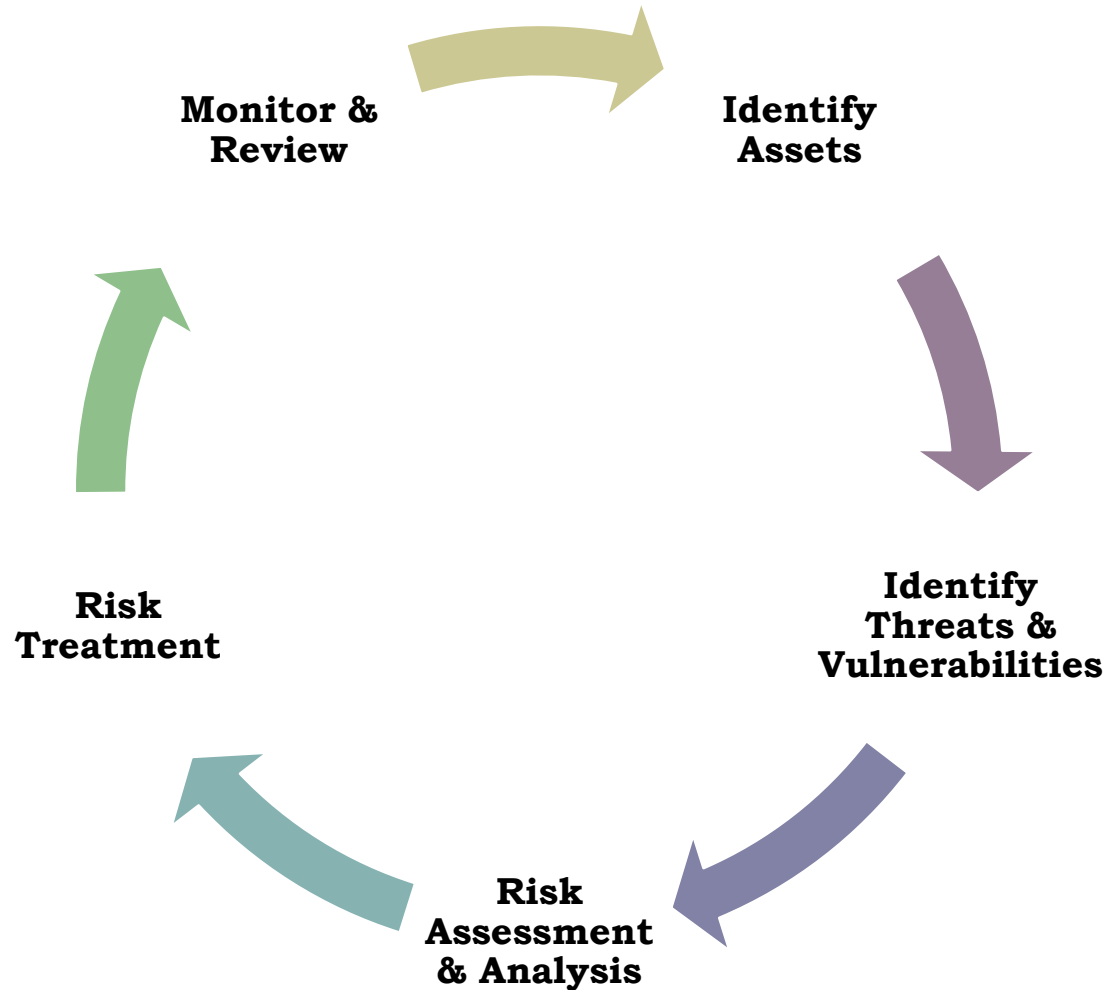


Risk Treatment

Strategy	Description	Example
Avoid	Stop risky activity	Close vulnerable system
Mitigate	Reduce risk	Patch + Firewall
Transfer	Shift risk	Cyber insurance
Accept	Accept risk	Risk is low & manageable



5 Key Phases of Cyber Risk Management



Monitor & Review

- Risk changes daily:
 - New vulnerabilities
 - New attack methods
 - Business changes
 - New systems
- Monitoring tools:
 - SIEM,
 - UEBA,
 - IDS/IPS,
 - SOC



Motives Behind Attacks



Motives Behind Attacks

- In Cyber attacks, one question that every investigator or analyst asks is

“Why did the attacker do it?”

- The motive behind the attack helps in determining:
 - ✓ Type of attacker
 - ✓ Level of sophistication
 - ✓ Likely next step
 - ✓ Best defense strategy.



Motives – Financial Gains

- When attacker want “**Money**”.
- **Examples:**
 - Ransomware (WannaCry, REvil, LockBit)
 - Credit card theft
 - Bank fraud
 - Cryptojacking
 - Online scams
- **Victims:**
 - Banks
 - Hospitals
 - E-commerce
 - Individuals



Motives – Espionage (Information Theft)

- Goal is “**stealing confidential information**”.
- **Examples:**
 - Government secrets
 - Military data
 - Corporate IP
 - Trade secrets
 - Research data
- **This is usually done by:**
 - Nation-state attackers
 - Corporate competitors



Motives – Ideology / Hacktivism

- Attacks based on **political, religious or social beliefs.**
- **Examples:**
 - Website defacement
 - Data leaks
 - DDoS to make statement
 - Social campaign attacks
- **Groups like:**
 - Anonymous,
 - LulzSec



Motives – Revenge / Personal Grudge

- Insiders or ex-employees attacking a company.
- **Examples:**
 - Data deletion
 - Account lockout
 - System sabotage
 - Data leaks
- **Most dangerous because insiders know:**
 - Systems
 - Passwords
 - Weak points



Motives – Curiosity / Challenge (Script Kiddies)

- Young hackers trying to prove skill.
- **Examples:**
 - Website defacement
 - Simple malware injection
 - Small DDoS attacks
- Usually unskilled but dangerous.



Motives – Cyber Warfare / Terrorism

- State sponsored cyber attacks.
- **Examples:**
 - Attacks on:
 - Power grids
 - Water systems
 - Transportation
 - Hospitals
 - Example: Turning off a city's electricity.



Motives – Competitive Advantage (Corporate Espionage)

- State sponsored cyber attacks.
- **Stealing:**
 - Client database
 - Product formula
 - Bidding strategy
 - Future plans
- Example: Steal product pricing before a tender



Need for Security



Need for Security

- Security is needed to protect data, systems, people, and business operations from misuse, attack, and loss.
- The need for security exists because today's world is fully dependent on digital data, systems, and networks. Without proper security, information can be stolen, damaged, misused, or destroyed - causing serious harm.
- Security is needed for:
 - ✓ Individuals, Businesses
 - ✓ Governments, Hospitals
 - ✓ Cloud systems, IOT devices



Why is Security Important?



Why is Security Important?

Protection of Confidential Data

- Organizations store sensitive information such as:
 - ✓ Personal data (Aadhar, PAN, passwords)
 - ✓ Banking information
 - ✓ Medical records
 - ✓ Business secrets
 - ✓ Government data
- If not protected → data leaks and identity theft happen.



Why is Security Important?

Prevention of Financial Loss

- Cyber attacks cause huge losses:
- Ransomware payments
- Legal fines
- System recovery costs
- Business downtime

Sometimes companies shut down due to cyber attacks.

Why is Security Important?

Business Continuity

Security ensures:

- Systems stay available
- Services do not stop
- Customers are not affected

No security = frequent downtime

Why is Security Important?

Protection Against Cyber Crimes

Major threats:

- Hacking
- Phishing
- Malware
- Ransomware
- DDoS
- Insider threats

Security is the only shield.

Why is Security Important?

Legal & Compliance Requirements

Laws require strong security:

- ISO 27001
- GDPR
- HIPAA
- IT Act
- PCI-DSS
- SOC-2

No security = legal action and penalties.



Why is Security Important?

Reputation & Trust

Customers demand:

- Privacy
- Secure transactions
- Trustworthy services

One data breach can destroy brand image forever.

Security Posture

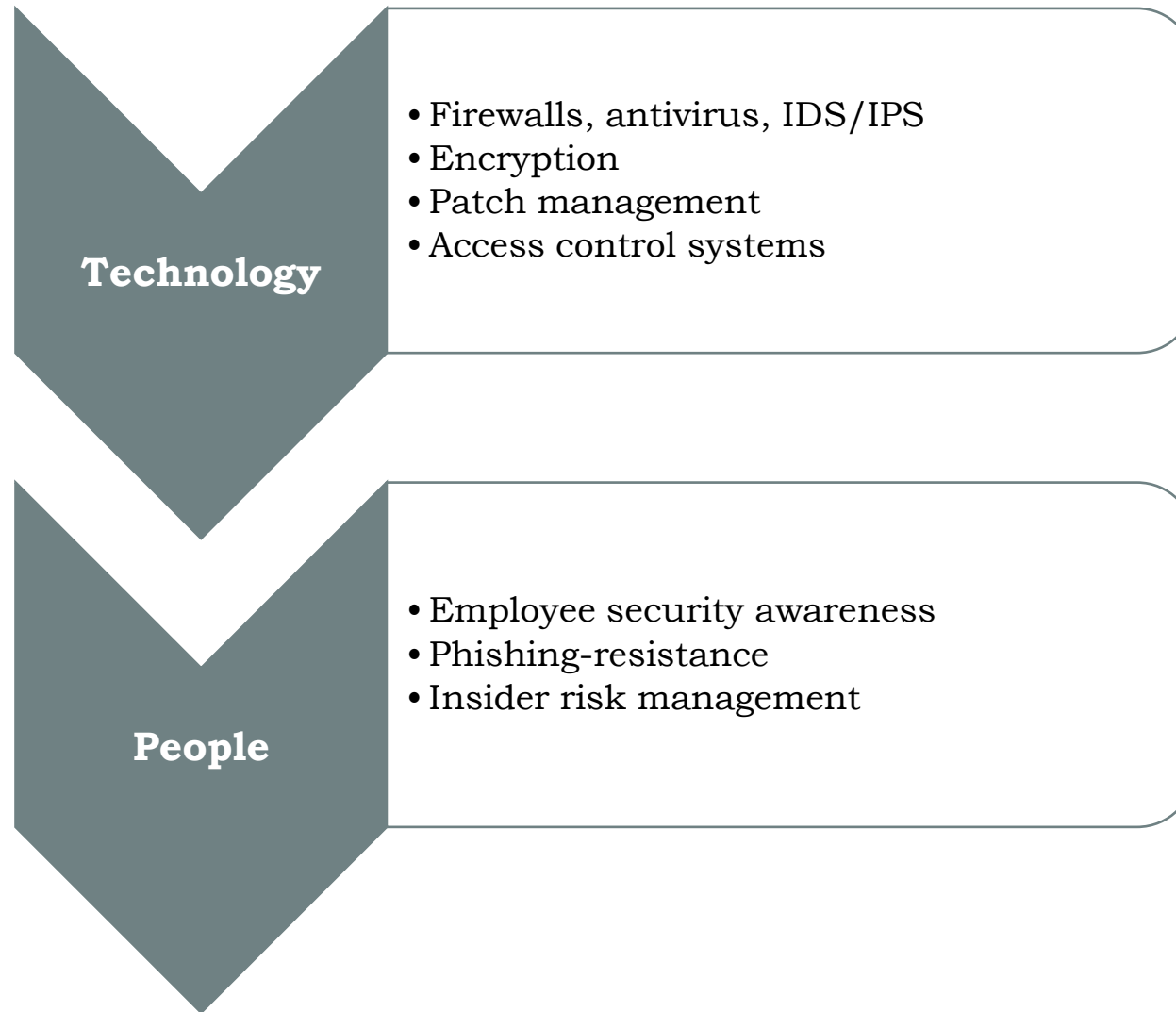


Security Posture

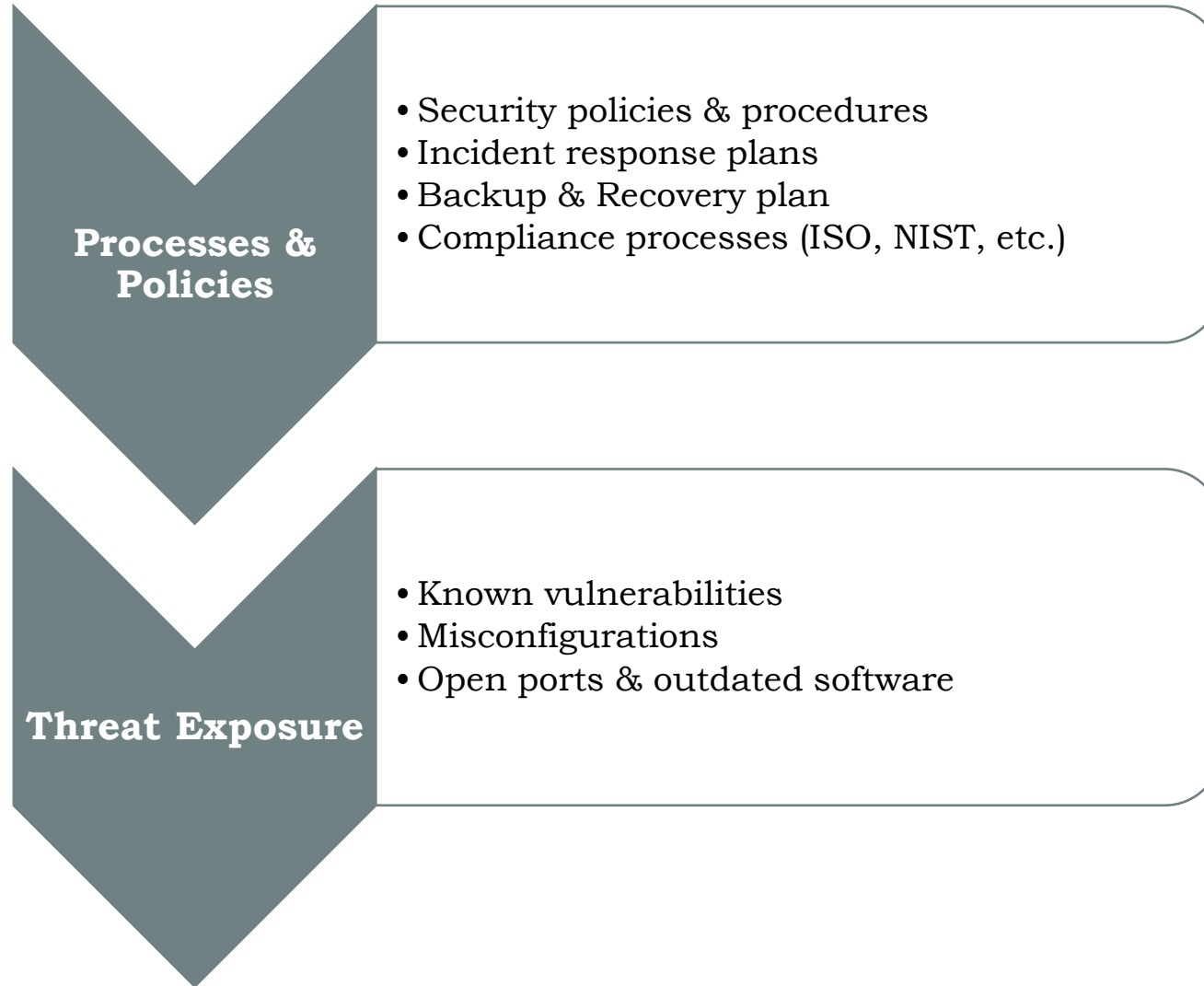
How secure and well prepared you are against attacks right now?

- Security posture is the overall strength of an organization's cybersecurity at any given time.
- It reflects how well systems, networks, people, and processes are protected from cyber threats.

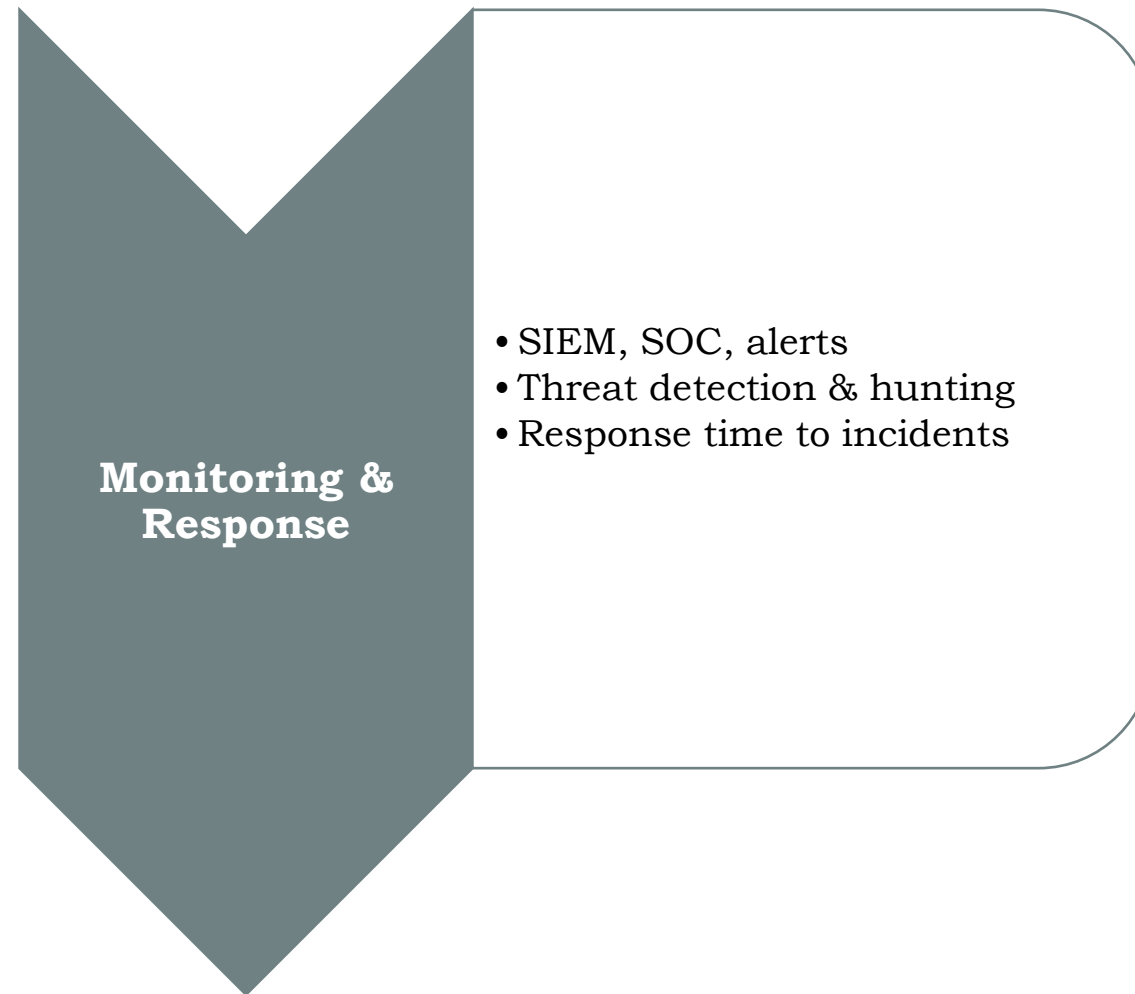
What makes up an organization's security posture?



What makes up an organization's security posture?



What makes up an organization's security posture?



Remember

Security Posture = Security Controls + Risk Management + Readiness Level

Additional - How to measure Security Posture?

1. Start with a Security Baseline (Framework Mapping)
2. Perform a Security Gap Assessment
3. Use a Security Posture Score
4. Measure Key Security Metrics (KPIs)
5. Test It Using Simulation
6. Use Posture Management Tools
7. Repeat the Process (Continuous Monitoring)





That's all Folks!